AIWeb CTF

Vulnerability Assessment & Penetration Testing Report

Victim hostname	aiweb2host.lan
Victim IP	192.168.31.175
Assessment	Authorized CTF / lab VM
Evidence	Five supplied screenshots; unrelated hosts redacted

Privacy: Unrelated discovered host names/IPs are removed from the host-discovery evidence. No personal Gmail address or password belonging to Nikhil Gowda is reproduced. The lab password hash is redacted in the evidence screenshot.

1. Executive Summary

The target exposes SSH on TCP/22 and HTTP on TCP/80. Nmap identified OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 and an Apache-hosted File Manager page. Gobuster discovered multiple web paths. Most importantly, the file-viewing endpoint appears vulnerable to path traversal/local file inclusion (LFI): the supplied screenshots show local /etc/passwd contents and content from /etc/apache2/.htpasswd. No successful SSH authentication, password cracking, remote code execution, or privilege escalation is demonstrated.

Findings summary

ID	Finding	Severity	Status
F-01	Path traversal / LFI through viewing.php	High	Confirmed by file disclosure screenshot
F-02	Apache .htpasswd content disclosed	High	File content shown; hash redacted
F-03	SSH exposed on TCP/22	Info–Medium	Service/version identified only
F-04	HTTP/Apache exposed on TCP/80	Medium	Service and paths enumerated
F-05	Potentially sensitive paths discoverable	Medium	401/403 responses; exposure not proven

2. Scope & Port Enumeration

Target: 192.168.31.175 (aiweb2host.lan). This report is based on screenshots rather than a fresh scan. Only the victim host is treated as in scope.

Port	Service	Observation and risk
22/tcp	SSH — OpenSSH 7.6p1 Ubuntu 4ubuntu0.3	Remote administration reachable. Verify patch status and SSH configuration. Evidence does not prove a specific SSH vulnerability.
80/tcp	HTTP — Apache; File Manager page title	Application file-viewing behavior allows local file disclosure according to the supplied evidence.

3. Detailed Findings and Proof of Concept

F-01 — Path traversal / Local File Inclusion (High)

Evidence: the browser URL uses the file_name parameter with repeated parent-directory traversal segments, and the response displays Linux account entries from /etc/passwd. This confirms a file-read issue beyond the intended application directory.

PoC (abbreviated): `http://192.168.31.175/viewing.php?file_name=[repeated ../ traversal]/etc/passwd`

Impact: Disclosure of operating-system files, usernames, application configuration, and any secrets readable by the web process. **Remediation:** avoid accepting arbitrary paths; use a strict allowlist; canonicalize and constrain paths to a dedicated content directory; apply least privilege; add traversal regression tests.

F-02 — Apache password-file disclosure (High)

Evidence: the screenshot shows content from /etc/apache2/.htpasswd returned by the same file-viewing endpoint. The hash is redacted from this report and the evidence image. Validity or reuse of the credential has not been tested.

Impact: Hash exposure can enable offline password guessing. **Remediation:** fix the LFI, restrict file permissions, keep password files outside web-readable paths, rotate the affected secret, and invalidate any reused credentials.

F-03 — SSH exposed on TCP/22 (Informational–Medium)

Evidence: Nmap reports OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 and SSH host keys. The screenshots do not show a successful login or an SSH exploit. **Remediation:** patch OpenSSH, prefer key authentication, disable direct root login, restrict source IPs, and monitor authentication logs.

F-04 — HTTP/Apache on TCP/80 (Medium in combination with LFI)

Evidence: Nmap reports an Apache HTTP service with a File Manager title. Gobuster discovers index.php, signup.php, logout.php, css/, srv/, webadmin, server-status and other paths. Response codes include 200, 301, 302, 401 and 403. These codes show response behavior but do not all prove vulnerabilities.

Remediation: remove unused routes, restrict admin/status endpoints, disable directory listing, and enforce authorization on the server side.

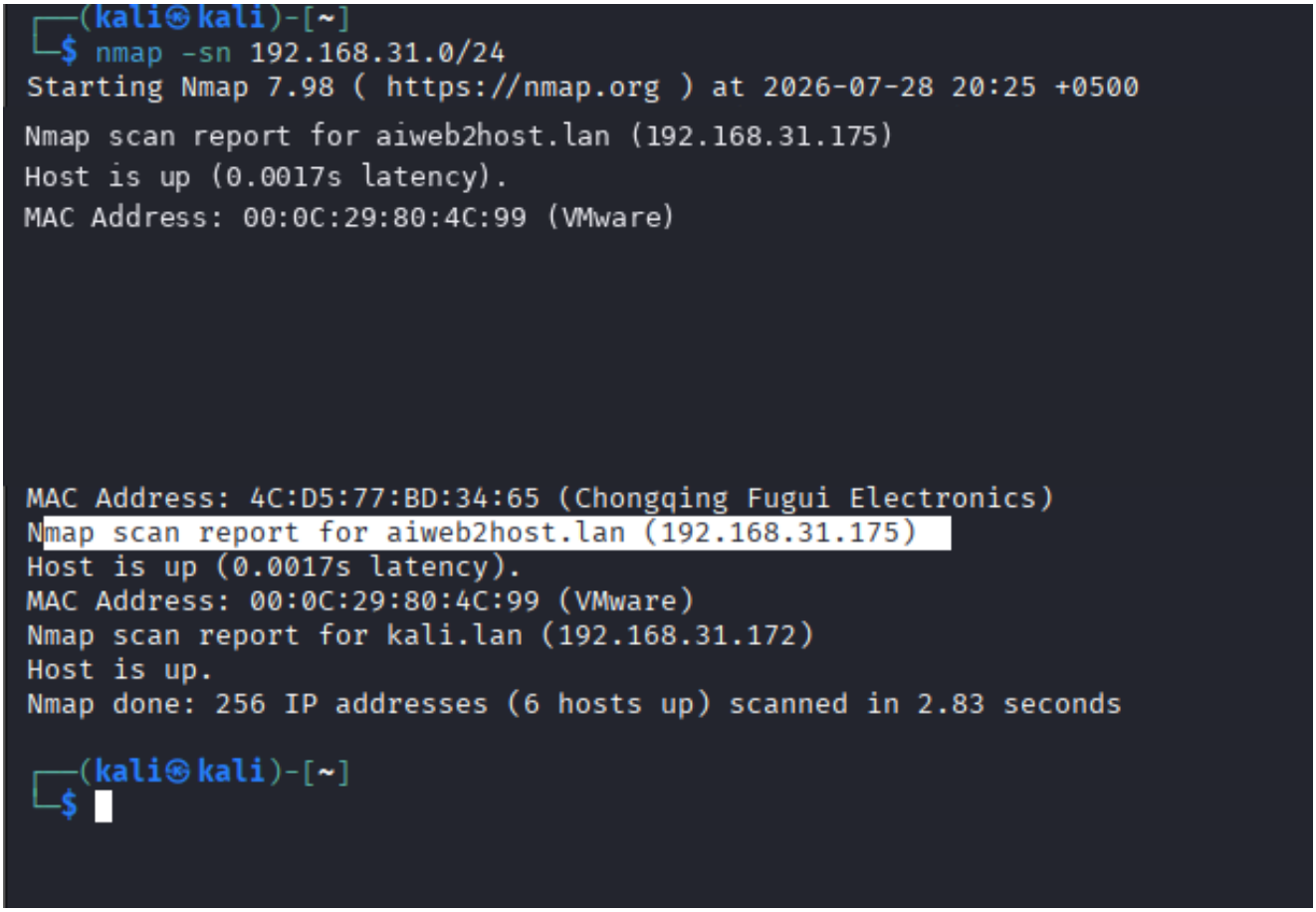
F-05 — Potentially sensitive paths (Medium, needs validation)

Evidence: dotfiles and administrative paths returned 401/403 responses. A 403 does not prove that file contents are exposed. **Remediation:** remove backup/configuration files from the document root, audit deployment artifacts, and restrict sensitive endpoints.

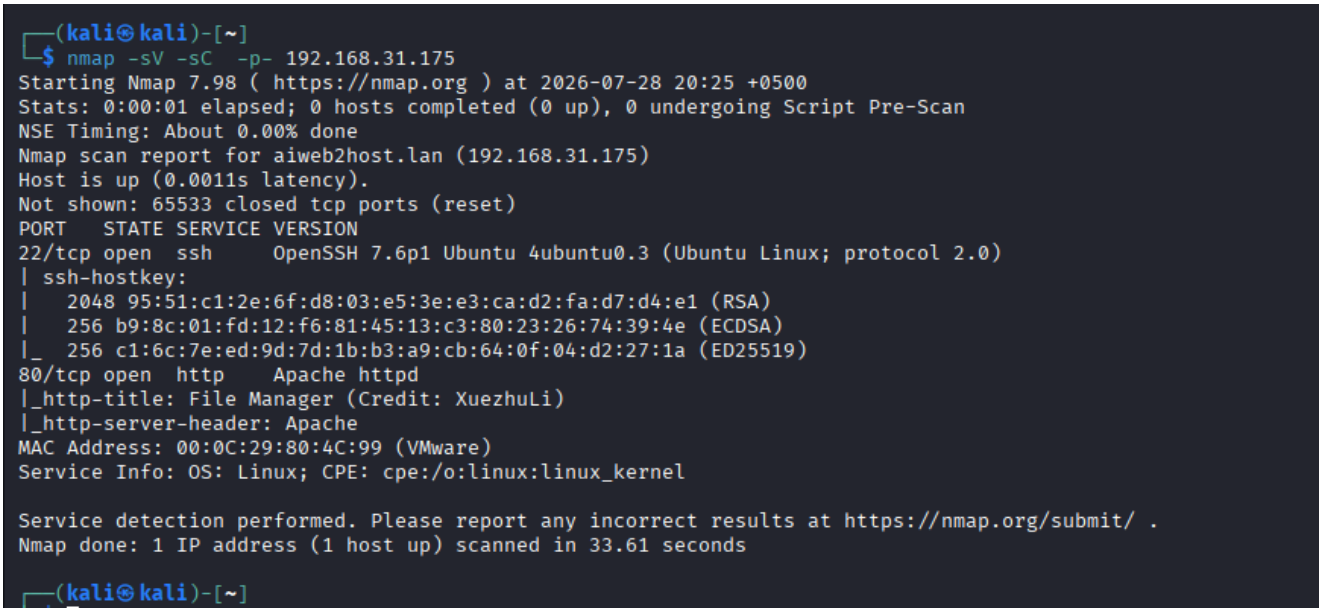
4. Screenshot Evidence

The host discovery image has been redacted to remove unrelated hosts/IPs. The password hash screenshot is redacted. Other screenshots are included as supplied.

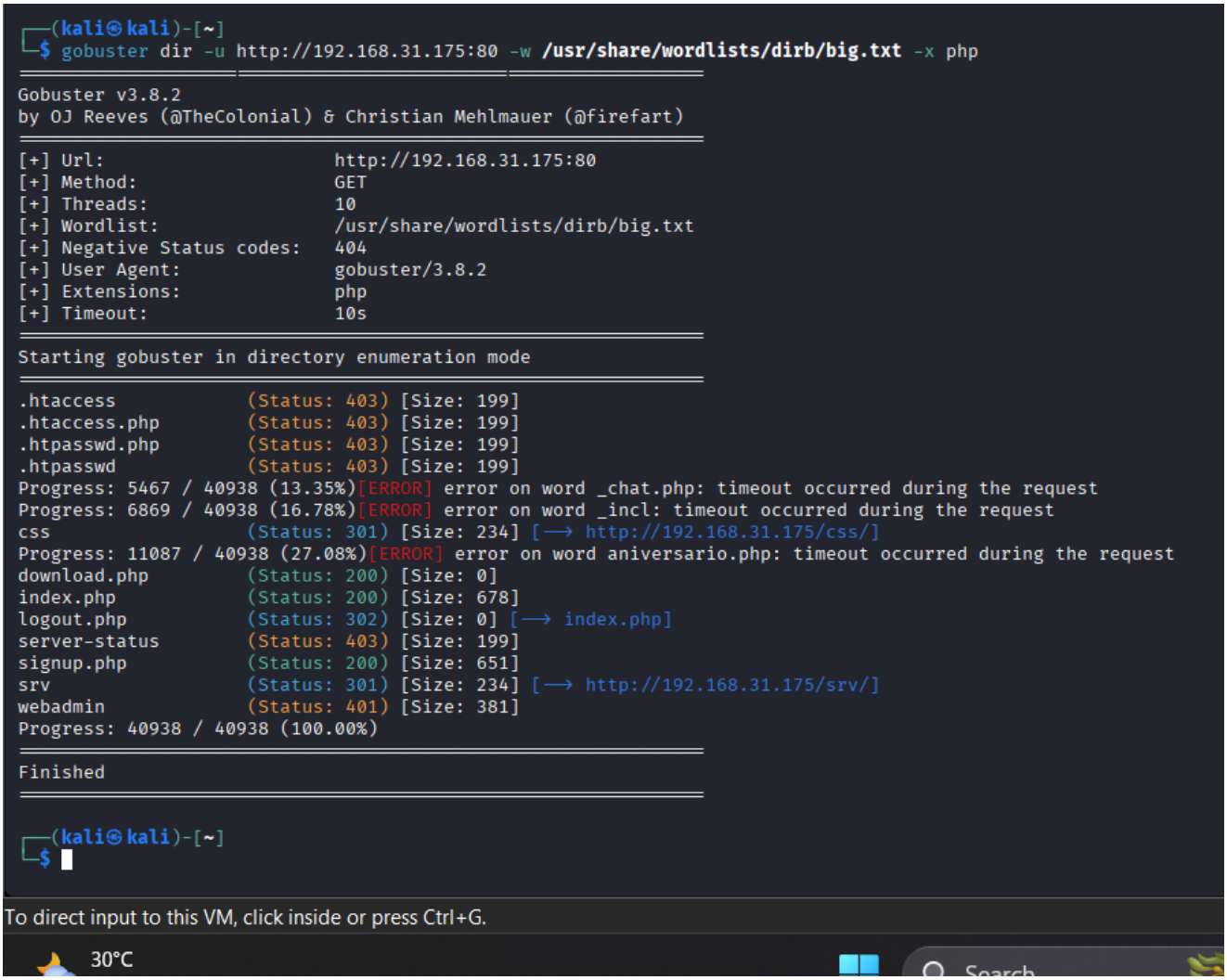
Evidence 1 — Host discovery; unrelated hosts redacted



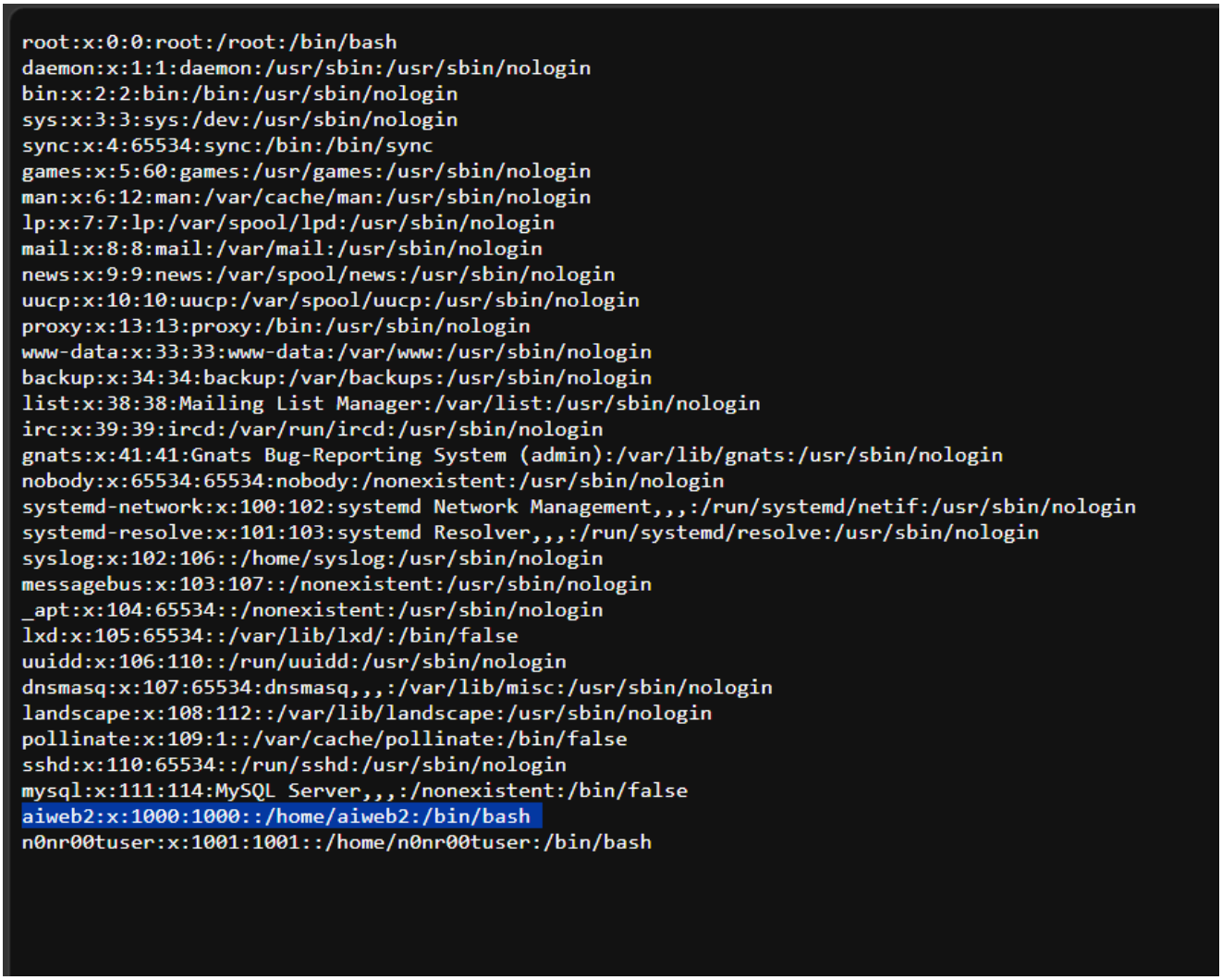
Evidence 2 — Nmap service/version scan of victim



Evidence 3 — Gobuster directory enumeration

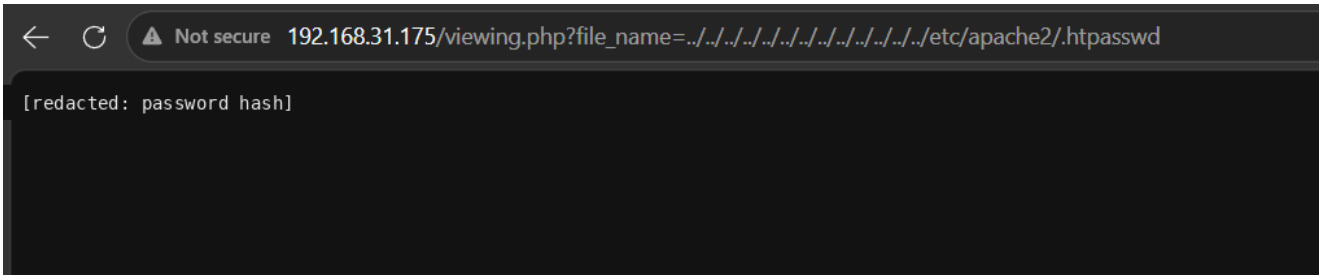


Evidence 4 — /etc/passwd disclosure



```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd/netif:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd/resolve:/usr/sbin/nologin
syslog:x:102:106::/home/syslog:/usr/sbin/nologin
messagebus:x:103:107::/nonexistent:/usr/sbin/nologin
_apt:x:104:65534::/nonexistent:/usr/sbin/nologin
lxd:x:105:65534::/var/lib/lxd/:/bin/false
uuidd:x:106:110::/run/uuidd:/usr/sbin/nologin
dnsmasq:x:107:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
landscape:x:108:112::/var/lib/landscape:/usr/sbin/nologin
pollinate:x:109:1::/var/cache/pollinate:/bin/false
sshd:x:110:65534::/run/sshd:/usr/sbin/nologin
mysql:x:111:114:MySQL Server,,,:/nonexistent:/bin/false
aiweb2:x:1000:1000::/home/aiweb2:/bin/bash
n0nr00tuser:x:1001:1001::/home/n0nr00tuser:/bin/bash
```

Evidence 5 — .htpasswd disclosure; hash redacted



5. Conclusion

The primary confirmed issue is local file disclosure through the web application's file-viewing endpoint, including access to operating-system account data and an Apache password file. Prioritize fixing the path-handling flaw and rotating exposed secrets, then harden SSH and HTTP. Retest in the authorized CTF environment after remediation.

Limitations: CVE applicability, credential validity, remote code execution, and privilege escalation were not independently verified from the screenshots.

End of report.